

BLACKBASTA

勒索组织内部泄密事件 分析报告

BLACKBASTA RANSOMWARE

CTC-RAN-18

绿盟科技C系列威胁情报专题报告



一、 事件背景	3
二、 组织背景	3
三、 泄露内容分析	4
3.1 组织技战术	4
3.2 组织情报分析	13
四、 针对本次事件的思考	15
4.1 防御勒索攻击	15
4.2 隐性网络战	15
4.3 LLM辅助威胁分析	15
五、 安全建议	17
5.1 “CT猎影”暗网威胁风险评估服务	17
5.2 “CT孪生”勒索演练服务	17
六、 参考	18

一、事件背景

2025年2月11日，勒索软件领域发生了一场轰动性事件——臭名昭著的BlackBasta组织内部聊天记录遭到泄露，近20万条俄语消息通过MEGA平台和Telegram频道被公之于众。这场泄露的起因可追溯至2024年年中，当时BlackBasta因攻击俄罗斯银行而引发内部激烈冲突，最终导致该组织在2025年初陷入停滞。泄露的聊天记录时间跨度从2023年9月18日至2024年9月28日，完整展现了该组织从鼎盛到内讧的全过程。这一事件不仅暴露了勒索团伙内部的脆弱性，也首次揭开了其运作模式和技术细节的神秘面纱。

绿盟科技M01N战队C威胁围猎小组长期对暗网威胁进行跟踪和预警，此次事件我们也快速进行了分析和研判，从该组织的起源，到泄露内容的深度剖析，再到事件背后的行业启示，我们将在本文中深入探讨，结合C小组前期狩猎情报数据，详细解读聊天记录中的关键线索，为读者全面呈现这场网络犯罪风暴的全貌。此外，绿盟科技C威胁情报小组针对企业用户提供行业独有的“CT猎影”暗网威胁风险评估服务和“CT孪生”勒索演练服务方案，读者可在文后进行了解。

时间	事件
2022年4月-2024年	BlackBasta活跃，攻击全球500多个组织，采用双重勒索策略。
2024年中	BlackBasta分支攻击俄罗斯银行，引发内部冲突，领导层决策受质疑。
2025年1月	因内部矛盾加剧，组织活动减少，部分成员转投其他勒索软件团如Cactus。
2025年2月11日	聊天记录泄露，时间跨度为2023年9月18日至2024年9月28日，泄密者为ExploitWhispers。

二、组织背景

BlackBasta勒索组织（CTC-RAN-18）于2022年4月首次现身，其起源被认为与Conti和REvil等知名勒索软件团伙密切相关，尤其是在Conti于2022年5月解散后，其成员可能重组并形成了BlackBasta。这一推测基于其战术、技术和程序（TTPs）与Conti和REvil的高度相似性，例如双重勒索策略和目标选择方式。BlackBasta采用Ransomware-as-a-Service（RaaS）模式运作，向附属黑客提供恶意软件，自身则负责谈判和赎金处理，这种模式使其能够迅速积累受害者并扩大影响力。

BlackBasta的攻击手法复杂且具有高度针对性，通常通过鱼叉式网络钓鱼电子邮件获取初始访问权限，随后使用PsExec等工具进行横向移动，并依赖Qakbot提升权限。其双重勒索策略不仅加密受害者的数据，还威胁在不支付赎金的情况下泄露数据，这种策略显著

增加了受害者的压力。此外，BlackBasta还采用多种防御规避技术，使其攻击更加隐蔽且难以检测。

BlackBasta之所以备受关注，不仅因为其攻击的广泛性和复杂性，更因为其对关键基础设施的针对性攻击，尤其是医疗保健行业。自出现以来，BlackBasta已攻击全球超过500个组织，包括多个地区的政府机构、金融机构以及医疗系统。2024年5月，其对某大型医疗系统的攻击更是影响了数百家医院，导致电话和计算机系统离线，部分医院甚至取消了非紧急手术。这种对关键基础设施的攻击不仅对受害者造成直接的经济损失，还可能对公共安全和社会稳定产生深远影响。因此，BlackBasta的持续演变和活动使其成为网络安全领域的重大威胁，值得全球范围内的关注和防范。

三、泄露内容分析

3.1 组织技战术

BlackBasta攻击组织展现出高度专业化、模块化的攻击能力，其技战术体系呈现出多层次、多维度的发展特征。该组织以勒索攻击为核心目标，构建了从初始渗透到数据外传的完整攻击链条，其技术手段涵盖了窃密口令、漏洞利用、社会工程学等多个领域，形成了完整的攻击生态。

在技术层面，该组织持续演进其攻击工具链，从传统的Cobalt Strike逐步向BRC4等新型C2工具迁移，同时积极采用商业化的PaaS（Packer-as-a-Service）服务进行载荷封装，以提升对抗检测的能力。在攻击策略上，该组织采用分阶段、模块化的攻击模式，通过投递器（Dropper）、远程访问木马（RAT）等工具逐步建立据点，最终实施勒索攻击和数据外传。

特别值得注意的是，该组织在攻击过程中展现出对合法工具的滥用能力，包括远程管理工具（RMM）的恶意使用，以及对企业常用软件漏洞的快速利用能力。

其攻击活动具有以下显著特征：

- **高度模块化**：在边界突破、据点建立、横向移动、数据渗出每个阶段，都配备专门的工具和技术方案。
- **商业化生态**：大量使用商业化的攻击工具和服务，包括MaaS（恶意软件即服务）、PaaS（打包器即服务）等，降低技术门槛的同时提升攻击效率。
- **持续演进**：密切关注安全防护技术的发展，及时更新攻击工具和策略，展现出强大的适应能力。

- 隐蔽性强：通过多层代理、流量混淆、合法工具滥用等手段，有效规避安全检测。
- 目标精准：采用鱼叉式钓鱼等针对性攻击手段，结合目标情报收集，提高攻击成功率。

在后续内容中，我们将详细分析该组织在各个攻击阶段的具体技战术，包括边界突破、据点建立、横向移动、命令控制等环节的技术细节和演进趋势。

3.1.1 边界突破-口令交易及漏洞利用

该组织起源于Conti等知名勒索组织，使得BlackBasta延续了其经典技战术，在边界突破上，该组织会购买Qakbot等知名恶意软件获取初始口令等访问权限如：cisco vpn、paloalto vpn、forticlient vpn、Microsoft Remote Desktop Web Access 口令等，可以看到其中不乏存在一些政府类目标。

```

https://cl:10443/remote/login;fleischmann;Camara00
https://ac.th/remote/login;chaturong.ch;Chaturong200232
https://z:10443/remote/login;CuchnaTom2;TomasCuchna123
https://uki.com.pk:10443/remote/login;Fort.Motors;RaU9UJxJ
https://telecom.com/remote/login;tuser10;@123456@
https://m.tw/remote/login;85120013;Mingche123456 FORTI VPN
https://e.it/remote/login;190558;9u7xzmhj
https://4:10443/remote/login;uye;p7t5ctp14
https://ss.interporto.it:10443/remote/login;DHL;DHL1894
https://vpngp.com/global-protect/login.esp;wjimenez;Wjr7906$
https://portal.du.sv/global-protect/login.esp;1511712020;03112001 paloalto vpn
https://sslvpn.bal-protect/login.esp;eve_proveedor;FeGyD#XW0TBu
https://access.ra.fr/global-protect/login.esp;mmarchais;m3Swysyljhuty057
https://vpn.cv.al-protect/login.esp;jbarsoum;Dahb6545.
https://webvpn.lobal-protect/login.esp;1036468;Viki1995
https://gp.apc.bal-protect/login.esp;jrasstrypdcra4;U#s$Ff19u007
https://e.ur.go.th/my.policy;02550;02550
https://me.dp.dunkinbrands.com/my.policy;gelido.maricar13@gmail.com;DunkInDonuts13
https://vr.om/my.policy;kdc;kdcl234
https://ic.haypacific.com/my.policy;englab1;comply#365 F5 NETWORK
https://ur.it.com.ph/my.policy;urc_lperalte;always
https://se.o.id/my.policy;kab.purworejo;7pwu7gpa
https://dj.alterminals.com/my.policy;C087;c087temp
https://fr.ross.or.th/my.policy;user2;trc@p@ss
https://ei.my.policy;siklosia.ELTE;n7WE36mT
https://asa(in.de/+CSCOE+/logon.html;tanurezajaya;ultimateweapon1P
https://vpn.it.bg/+CSCOE+/logon.html;DENCHEVA;789456
https://vpn/CSCOE+/logon.html;56709535;toon02 CISCO VPN
https://bri/+CSCOE+/logon.html;vanessa.molina;C0nstant1n0!4.
https://vpn/logon.html;ax17082;Rusovaiela28
https://vpn/CSCOE+/logon.html;Hbenghor;bibo1920
https://vpn/CSCOE+/logon.html?reason=12&msg=5848454F4E512D504E594C48#form_title_text;calyx;GpEgFd~4!Q
https://vpn/CSCOE+/logon.html;ardan;ta4269
https://vpn/o/+CSCOE+/logon.html;71379407;Isvimed2021*
https://vpn/CSCOE+/logon.html;amveu;Gepardoi-
https://lin/fi/+CSCOE+/logon.html;vpn@porvoonautotaryike.fi;T0yot2PRV5
https://rds.m/rdweb/pages/en-us/login.aspx;Herve.Viengluang;Dress.boss11
https://ras.web/pages/en-us/login.aspx;jawadtruck1982@bcloud.ca;30t018#$
https://webn.orp.com/rdweb/pages/zh-tw/login.aspx;pega;weite_yang;ww652411
https://dyna.co/rdweb/pages/en-us/login.aspx;rawafid\AKHussain;ah@2019
https://rds/rdweb/pages/en-us/login.aspx;asapinc\748aifftp;Operations1
https://rds1/rdweb/pages/en-us/login.aspx;cloud\bm-pphpj01;P@ssw@rd12345
https://clou/web/pages/it-it/login.aspx;IT_commerciale@cloud.assi.it;Lucaroby21
https://desk.ll.derbyshire.sch.uk/rdweb/pages/en-us/login.aspx;antgell\19willa;Quietly?1
https://gate.it/rdweb/pages/es-es/login.aspx;onwork\tpiracero;zxCD21$
https://schu/rdweb/pages/de-de/login.aspx;snbs\marco.eder;16.08.2002
https://vdi/pages/en-US/login.aspx;jessica.pais.correia@ubi.pt;Ydqooufm089.
https://hcm.u.br/rdweb/pages/en-us/login.aspx;rsmbrazil.com.br\jose.sousa.s;<1s4@3s1$D0gs>1
https://erp.ia/rdweb/pages/en-us/login.aspx;db.admin@nbkreadymix.qa;#e7c7G1J1
https://darp/rdweb/pages/en-us/login.aspx;KVS\0201000059930005;KVS@DL1234
https://apps.id.aero/rdweb/pages/en-us/login.aspx;bwa\shpeters;P@ssword
https://rds/rdweb/pages/en-us/login.aspx;SSGWEB\ALT_Martin;cIBm*355338

```

图1 多种VPN设备口令

同时其还搭建并长期维护一个爆破网络，从记录显示来看，其每个月用于爆破服务器的开销为625\$，其中包含数个爆破节点以及大量爆破产生的流量费用。以爆破cisco、rdweb、forti口令等进行目标突破。

并且时刻关注高价值应用漏洞，像GlobalProtect RCE（CVE-2024-3400）、Fortinet FortiOS RCE（CVE-2024-1762）、ScreenConnect RCE（CVE-2024-1709）等，同时会问一些0day服务商购买一些RCE 0day进行初步的攻击活动。

3.1.2 边界突破-社工钓鱼技战法演进

1) 鱼叉式钓鱼攻击为主的定向钓鱼

该组织成员分工明确，擅长高针对性钓鱼诱骗，组织内部长期维护一份攻击目标列表。首先会从勒索价值层面筛选高价值目标公司，然后会选择泄露信息较多和高权限的内部员工，从而提高边界突破的概率。

根据聊天记录和泄露的大量钓鱼页面和钓鱼域名来看，表明他们特别喜欢选取vpn、sso等企业入口，进行凭据钓鱼攻击。

```
{
  timestamp: 2024-04-18 10:58:39,
  chat_id: !H0wizKpRWUvwqLnQAt:talks.icu,
  sender_alias: @nickolas:talks.icu,
  message: A ты можешь мне примеров авторизаций пользовательских дать, форти и циско, хотим посмотреть что можно придумать для фишинга.
}
{
  timestamp: 2024-04-18 11:00:07,
  chat_id: !H0wizKpRWUvwqLnQAt:talks.icu,
  sender_alias: @Usernameegg:matrix.bestflowers247.online,
  message: Forti
omicranes.com https://173.225.227.162:10443 dpieczynski@omicranes.com Salute10
}
{
  timestamp: 2024-04-18 11:00:20,
  chat_id: !H0wizKpRWUvwqLnQAt:talks.icu,
  sender_alias: @Usernameegg:matrix.bestflowers247.online,
  message: Cisco
whitecube.com https://5.148.155.39:443 AnyConnectWhiteCubeVPN tesscontla 30Bjasper
}
{
  timestamp: 2024-04-18 11:00:33,
  chat_id: !H0wizKpRWUvwqLnQAt:talks.icu,
  sender_alias: @Usernameegg:matrix.bestflowers247.online,
  message: Sonic
gsinvestments https://75.146.34.89:4433 gsinvestments.local john GS1invest
}
{
  timestamp: 2024-04-18 11:00:49,
  chat_id: !H0wizKpRWUvwqLnQAt:talks.icu,
  sender_alias: @Usernameegg:matrix.bestflowers247.online,
  message: Citrix
hodges.edu https://198.17.79.21:443 hodges\amcelroy Sullivan1!
```

图2 VPN钓鱼聊天记录

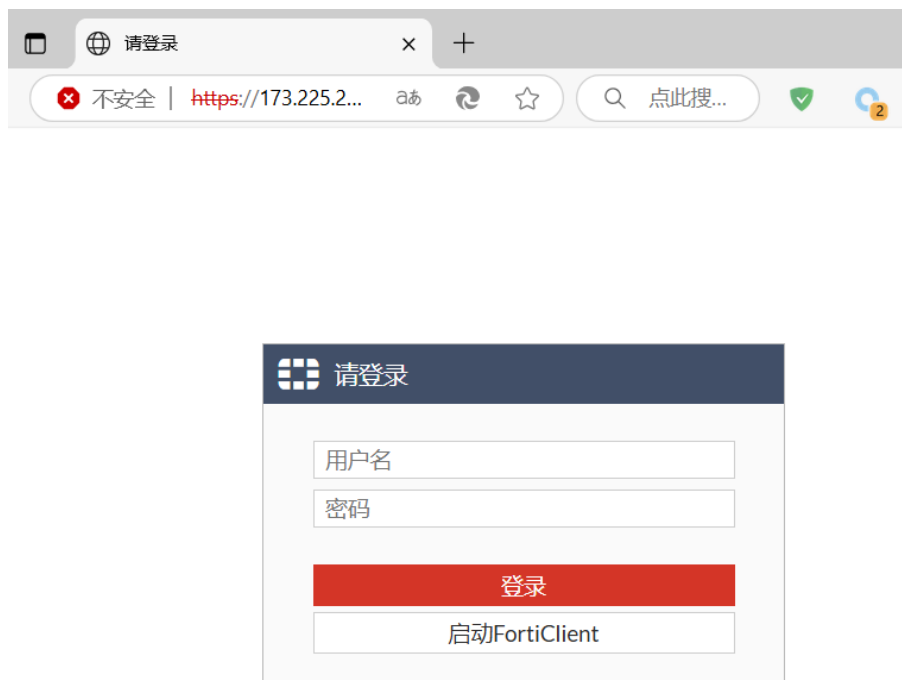


图3 仿冒的VPN钓鱼页面

2) 钓鱼策略复杂多样

该组织的钓鱼手段策略较为复杂，除了使用传统的邮件直接与目标接触外，还擅长使用电话和teams进行钓鱼攻击。

在电话钓鱼前，攻击者会提前收集掌握目标人员的身份信息，包括姓名、手机号、邮箱等，在电话接触前先发送大量可疑邮件，从而引起目标恐慌，然后打电话冒充技术支持人员，并利用掌握到的信息获取信任，从而诱骗受害者安装RMM软件进行主机控制。

```
{
  timestamp: 2024-04-19 16:13:15,
  chat_id: lnPsXVWwVnfpPbfsDcD:matrix.bestflowers247.online,
  sender_alias: @usernamegg:matrix.bestflowers247.online,
  message: Если в сообщении фигурирует фамилия и имя, фото и персональные данные цели, получатель приобретает уверенность, что имеет дело с подлинным отправителем, что увеличивает
результативность фишинговой атаки.
}
я мы же шлем по ответам
это хороший конфирм должен быть
}
{
  timestamp: 2024-04-19 16:13:30,
  chat_id: lnPsXVWwVnfpPbfsDcD:matrix.bestflowers247.online,
  sender_alias: @usernamegg:matrix.bestflowers247.online,
  message: Примеры:
  "Имя фамилия, Ваш аккаунт заблокирован! Для восстановления доступа перейдите по ссылке!"
  "Обновите информацию и получите кэшбек и бонус!"
  "Подтвердите информацию прямо сейчас и получите бесплатную доставку!"
  "Microsoft 365: Необходимые действия: обновите адрес для подписки на Xbox Game Pass для консоли"
  "Workday: Напоминание: Требуется Важное Обновление Системы Безопасности"
  "Twitter: Предупреждение о безопасности: новый или необычный логин в Твиттер"
  "Amazon: Требуется действие | Ваше членство в Amazon Prime было отклонено"
  "Zoom: Ошибка Запланированного Собрания"
  "Google Pay: Отправлен платеж"
}
```

图4 部分钓鱼话术主题

积极利用TeamsPhisher开源工具，针对teams目标员工进行钓鱼攻击，攻击者会构造迷惑性名称，让受害者误以为是目标组织的公共部门，如：信息支持、行政管理等。

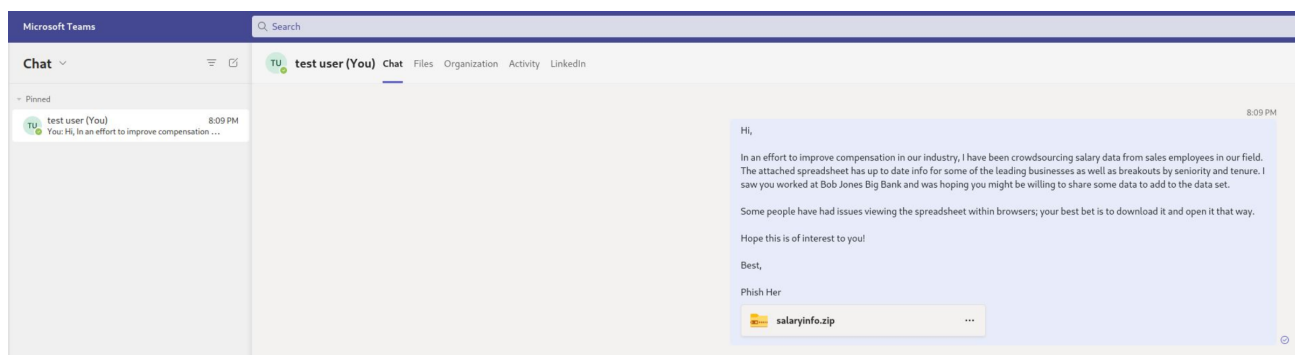


图5 TeamPhisher社工工具

3) 积极利用商业钓鱼平台和新型钓鱼技术

2024年开始，攻击者开始考虑迁移至勒索地下生态的，商业社工钓鱼辅助平台，该平台能够生成恶意挂马页面及文档，欺骗用户点击下载载荷，绕过web标记和本地杀软。

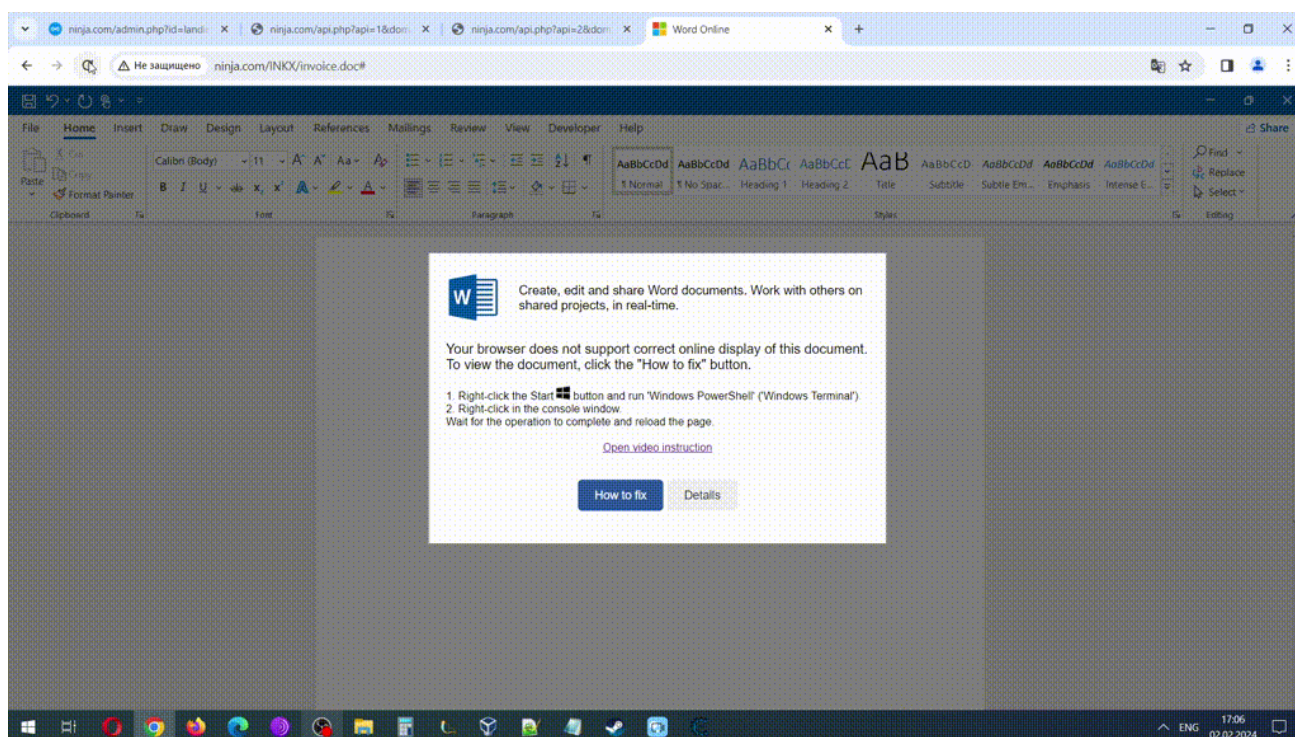


图6 商业钓鱼平台挂马页面

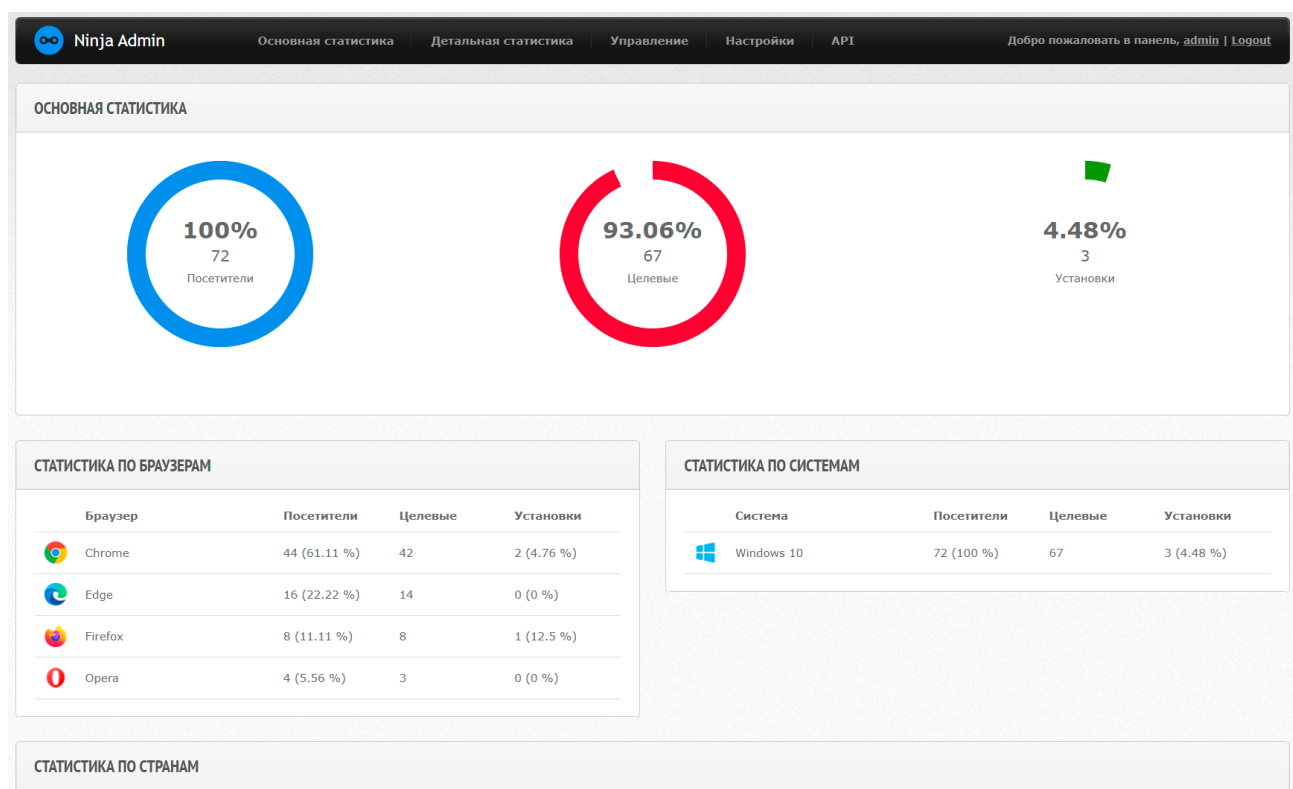


图7 商业钓鱼平台项目数据展示页

3.1.3 建立据点-分阶段木马&商业载荷打包平台

攻击者采用多阶段载荷执行策略，通过分阶段交付恶意软件来建立据点。这种方法包括使用投递器（Dropper）初始感染系统，进一步部署远程访问木马（RAT）如Pikabot。这种分阶段方法能让每个阶段看起来较不显眼，从而提高整体攻击的成功率。

攻击者倾向于购买商业服务，如恶意软件即服务（MaaS），以获取预制且具有规避能力的恶意软件，降低技术门槛。除此以外，攻击者倾向于利用商业PaaS(Packer-as-a-service)商业载荷打包平台对样本进行进一步的处理，以应对不同的av/edr强对抗场景。

1) Dropper-商业载荷投递器

投递器是多阶段攻击策略的起点，为后续更复杂的恶意活动铺平道路。它具备快速生成、快速抛弃和批量投递的特点，作为一道屏障，减少主控木马直接暴露的风险，同时通过短暂的生命周期和多样化的分发方式增加溯源难度。 BlackBasta倾向于借助商业服务确保投递器的基础免杀能力，同时根据目标环境和攻击需求，灵活选用HTA+JS或DarkGate等不同投递器，以兼顾隐蔽性、对抗性和适用性。

攻击者常使用一类商业载荷投递器，以HTA和JavaScript为核心。通过结合HTA文件加载JavaScript脚本，这类投递器能通过链接或邮件分发，最终在受害者系统上执行EXE或MSI格式的恶意载荷，操作简单且易于隐藏。

DarkGate是其使用的另一款商业载荷投递器，以其强大的对抗性著称。自2018年首次发现以来，DarkGate持续活跃，能够下载并运行其他有害程序。作为多用途恶意软件工具包，它常用于发起勒索软件等复杂攻击，凭借多态shellcode、全加密通信等高级规避技术和快速执行能力，远超普通下载器，对攻击者极具吸引力。

2) RAT-轻量级远程访问木马

RAT是攻击者用于远程操控受害者系统的工具，处于承上启下的关键位置。它通过批量上线控制大量目标，为下一阶段的主控C2木马载荷铺路，同时具备一定的对抗能力，以确保在感染初期的隐蔽性与稳定性。BlackBasta偏好商业化的RAT解决方案，以确保基础的对抗能力与部署效率。通过从Qakbot转向Pikabot，他们灵活适应执法压力，利用不同RAT的特性满足远程控制与后续攻击的需求。

攻击者最初依赖Qakbot作为主要的RAT工具。然而，自Qakbot在23年4月份执法行动中被取缔后，他们转向Pikabot。Pikabot是一种模块化后门木马，自2023年初亮相以来迅速崭露头角。它支持执行任意命令、注入恶意代码，并采用反虚拟机、反调试、间接系统调用及运行时字符串解密等高级规避技术，使其在沙箱环境中难以被分析，大幅提升隐蔽性与生存能力。

3) PaaS-商业化载荷加壳平台

PaaS（Packer-as-a-Service，打包器即服务）是一种提供载荷封装的商业化服务平台，帮助攻击者通过自动化工具生成免杀样本，以适应多样化的攻击需求。BlackBasta利用PaaS服务封装其载荷，有效提升隐蔽性、对抗性和部署效率，降低自身开发成本并规避检测。

Crypto平台是一种商业化载荷加壳器，其核心优势在于支持多种模板自动化生成免杀样本，内置系统调用等对抗技术。它能够对Cobalt Strike等主流C2武器的载荷进行封装，帮助攻击者在规避检测的同时快速适配目标环境。BlackBasta借助Crypto等商业化PaaS服务，确保载荷具备基础免杀能力与对抗性。通过灵活选择打包方案，攻击者能高效应对不同场景的防御机制，提升攻击成功率。

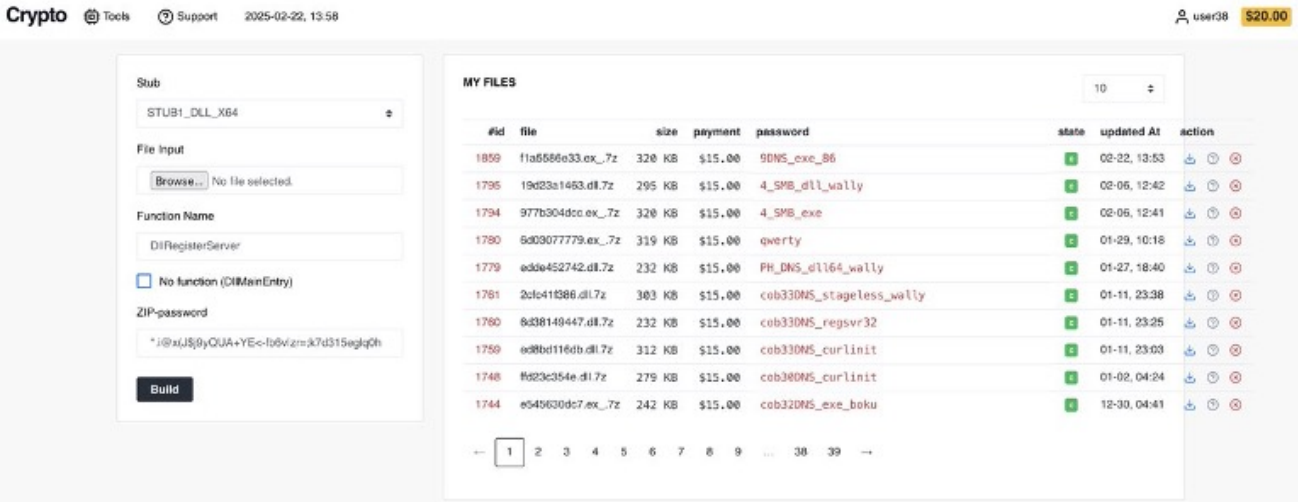


图8 Crypto 商业化载荷加壳免杀平台

3.1.4 命令控制-商业化C2工具&RMM

1) 主控C2由CobaltStrike向BRC4转变

该攻击组织以Cobalt Strike（CS）作为主控C2，结合插件运行，展现出高度的专业性与针对性，尤其关注内存对抗及绕过AV/EDR检测，并始终采用最新版本，从4.8升级至4.9。其工具集涵盖内存对抗、域内攻击、信息收集、样本免杀和行为隐蔽等多个领域，通过融合官方插件与开源工具，灵活调整策略以提升攻击效率并规避安全检测。这反映了其深厚的技术能力、对目标环境的深刻理解以及模块化、多样化的攻击框架，使其能够有效应对复杂的企业网络环境。除此以外，BlackBasta还使用RedGuard、BounceBack 前置设施隐藏自己的CS服务基础设施，增强了该组织的隐蔽性。

插件名称	插件来源	类别
boku.cna	开源插件	内存对抗
elusiveMice.cna/mice.cna	开源插件	内存对抗
kerbeus_cs.cna	开源插件	域内攻击
MachineAccounts.cna	开源插件	域内攻击
SA.cna	开源插件	信息收集
CustomProcessColors.cna	无	攻击辅助
ProcessColor.cna	开源插件	攻击辅助
FilesColor.cna	开源插件	攻击辅助

arsenal_kit.cna	官方插件	样本/行为/内存对抗
-----------------	------	------------

由于Cobalt Strike在对抗性方面逐渐暴露出局限性，该攻击组织从2024年初开始积极探索并切换到BRC4（Brute Ratel C4）作为其新的C2工具。这一转变标志着其在技术策略上的重大调整，旨在提升攻击的隐蔽性和成功率。尽管BRC4在某些场景下可能会触发Cortex和Cylance等安全产品的警告，但其在设计上具备更强的对抗性，尤其是在绕过EDR检测和模拟合法行为方面表现出色。因此，该组织将其作为Cobalt Strike的替代方案，并计划通过优化配置或结合其他技术手段来规避安全告警，显示出其在技术升级和对抗防御方面的持续适应能力。

2) 滥用合法远程管理工具RMM

攻击者通过滥用合法远程管理工具（RMM）对目标系统实施补充的命令与控制（C2），利用这些工具的合法性与功能性掩盖恶意行为。这些RMM工具因其合法用途广泛应用于IT管理，攻击者利用其固有特性（如加密通信、便携部署和系统级权限）实现隐蔽的命令控制。它们能绕过防病毒软件和EDR检测，因其行为与正常管理活动高度相似。此外，攻击者常通过社交工程或漏洞利用部署这些工具，进一步提升隐蔽性与成功率。例如，AnyDesk和TeamViewer常用于快速建立C2通道，而Tactical RMM和MeshCentral的开源特性使其更易被定制用于恶意目的。

工具名称	类别	使用RMM进行命令控制在隐蔽性方面的优势
AnyDesk	远程桌面控制	轻量化便携式执行文件无需安装，利用合法证书绕过安全检测，流量加密隐藏C2通信。
TeamViewer	远程访问与支持	广泛使用且受信任，快速部署无需复杂配置，攻击者可通过社交工程诱导用户安装，难以与合法使用区分。
Syncro	远程监控与管理	集成MSP功能，支持脚本执行与持久化，流量融入正常管理活动，降低被标记为异常的可能性。
Wise RMM	IT管理与监控	提供全面设备管理功能，攻击者可利用其内置工具执行命令，伪装成管理员行为，隐蔽性高。
Tactical RMM	开源远程管理	开源特性便于定制与混淆，结合MeshCentral提供快速远程控制，绕过传统检测机制。
MeshCentral	远程桌面与管理	支持跨平台与浏览器访问，端到端加密通信，开源性质使其易于修改，隐藏恶意活动于合法流量中。

3.1.5 横向移动-域内攻击

该组织使用powershell命令进行域内的初步信息收集，同时也使用BloodHound进行域内数据分析，其常使用Cobalt Strike中的.NET反射加载，利用Rebeus、SharpShares、SharpSecDump、ShadowSpray等工具进行域内的信息收集和横向移动，同时在该组织的聊天中发现其也熟练掌握impacket、certify等工具的攻击利用方式。更值得关注的点在于其对Kerberoasting攻击的熟练利用，在勒索生态链条中存在对于加密口令爆破的服务商，通过对Kerberoasting产生的口令进行爆破，达成直接访问域内重要系统的目的。

```
456: $krb5tgt$235$qlserver2008$...$MSSQLSvc/HOSQL13.reh.ed-ms.com:1433*$a4dc070bb167aa569f9...4b157ab6b6:SQLServer2008
491: $krb5tgt$235$admin_adfs$domain-l...local$host/...local$287aac...388b9:04cccf
493: > @usernameboy:matrix.bestfloweers247.online> $krb5tgt$235$admin_adfs$domain-baccarat.local$host/...domain-l...local$287aac...388b9:04cccf
504: $krb5tgt$235$ksuzuki$...$MSSQLSvc/...:23498...$02b98045c198fadd33c82f82cc3ea4ba$bcdb69a4f646badaaba91ae362e9030a7726a4551e9e3e146955e814404a
507: > @usernameboy:matrix.bestfloweers247.online> $krb5tgt$235$ksuzuki$...$MSSQLSvc/dl011...:23498...$02b98045c198fadd33c82f82cc3ea4ba$bcdb69a4f646badaaba
581: $krb5tgt$235$rravi$baccarat.local$MSSQLSvc/loanernj2...local:1433@baccarat.local*$a846...3e7c3:3737intel8
582: > @usernameboy:matrix.bestfloweers247.online> $krb5tgt$235$rravi$...local$MSSQLSvc/loanernj2...local:1433@baccarat.local*$a846...3e7c3:3737intel8
958: $krb5tgt$235$seadevscrsvc$...org$HOST/seadevscrsvc$...org*$3eef6...56d2:8PassWord123$
2024: $krb5tgt$235$PRODSQLDW$...org$MSSQLSvc/PRODSQLDW...org:1433@path.org*$df056d925f...b441a5901:2gdfpos
2476: $krb5tgt$235$svc_qlagent$...co.uk$MSOLAPSvc.3/V-12SUDB028...co.uk*$11e32020f19324b3c53...85faab27fb:symbad69
2477: $krb5tgt$235$SPRS...co.uk$SPR/V-12SSPR018...co.uk*$869ab2790ef46...60alf8ca9d7:Sp3c0p5!
2479: $krb5tgt$235$SVC_SPRM5...co.uk$SPR/V-12SPRM018...co.uk*$98d56f...abc9e26:Sp3G0p5!
```

图9 Kerberoasting凭据爆破

从上图我们可以看出，当企业安全产品告警了Kerberoasting攻击后，一定要产生警惕，并及时自查涉及的Kerberoasting账号，做到对应账号的口令修改，才能在制止住下一步的攻击活动。

3.2 组织情报分析

3.2.1 组织演变：源起Conti与Revil，重大事件导致品牌重塑

1) 组织溯源与人员构成

BlackBasta组织作为近年来活跃的勒索软件组织，其核心成员主要来自两大知名网络犯罪集团：Conti和Revil。这一人员构成不仅为BlackBasta带来了成熟的技术能力，也使其继承了前组织的运作模式与犯罪经验。

Когда ситуация переходит в политическое русло, она становится опасной. Главных рисков два.

- Первый, самый главный, это то, что эту атаку объявят действием враждебного государства. Судя по всему, настроения у местной ГБ-ни именно такие. Неделю назад, когда BlackSuit ударил по Октафарма (это швейцарско-американская компания-донор-плазмы), в новостях эта атака подавалась как "враждебные действия России". Плюс, конти и так под санкциями. А мы в сознании полицейев часть конти. При таком раскладе, заплатить нам будет нельзя, потому что это будет "спонсирование враждебного государства", а это дело подсудное. Более того, сейчас санкции реплицируются по странам. Я думаю, ты помнишь недавнее дела Ермакова с Ривела, которого поставили в санкционные списки США, Британия и Австралия, хотя атаковал он только один австралийский банк. То есть весь запад тут действует сообща.

- Второй риск, и он не противоречит первому, это то, что полиция, чтобы не рисковать погонями, предпримут "атаку возмездия". Не очень понимаю, что они могут сделать конкретно в нашем случае, но как ты видел по трику и по квакботу,

当局势转向政治时，就变得危险了。主要有两个风险。

首先，最重要的是，这次袭击将被宣布为敌对国家的行动。显然，当地GB的情绪并非如此。一周前，当BlackSuit攻击Octafarma（一家瑞士-美国血浆捐献公司）时，新闻报道称这次攻击是“俄罗斯的敌对行为”。另外，Conti等人受到制裁，我们在警方的意识中是Conti的一部分。在这种情况下，我们不可能付钱给我们，因为这将是“敌对国家的赞助”，而这又是一个有管辖权的问题。此外，制裁现在在各国重复。我想你还记得最近Yermakova和Rivel的案件，Rivel被美国、英国和澳大利亚列入制裁名单，尽管他只攻击了一家澳大利亚银行。也就是说，整个西方都在一起行动。

第二个风险，也不与第一个风险相矛盾，是警察为了不被追捕的风险，会采取“报复攻击”。我不太明白他们在我们的情况下能做什么，但正如你在trick和quakbot上看到的，他们的手很长。我不认为这是致命的，但即使停止我们的工作3-4周，它已经是相当严重的伤害。事实上，夸克的情况显示了这一点。

因此，在最糟糕的情况下，我们可能会发现自己在2022年陷入Conti的境地。也就是说，我们可以工作，攻击继续，但目标不支付，因为支付禁止当局，制裁的威胁。这意味着重塑品牌，更改服务器等。这也会阻碍工作。

图10 BlackBasta内部记录揭露与Conti关系

2) 重大事件影响，品牌重塑进行中

2024年5月，BlackBasta组织针对美国Ascension医疗机构发起大规模勒索攻击，导致560万患者的医疗数据与医疗服务受到严重影响。这一事件引发了美国执法部门的高度关注，并招致社会各界的强烈谴责。

鉴于此次攻击事件造成的恶劣影响，BlackBasta组织已明确表示将进行品牌重塑。其核心成员透露，组织正在实施"品牌重塑"计划，这也与外部观察到的BlackBasta的活跃度降低相印证，具体步骤如下：

- 逐步建立新的组织标识与运作模式
- 在过渡期内保持新老品牌的并行运作
- 调整攻击策略以规避执法部门的追踪

3.2.2 BlackBasta勒索组织人员结构与职能

本次BlackBasta勒索组织内部情报的泄露，彻底揭示了其严密的组织架构和职能分工。该组织由多个核心成员构成，各自承担着不同的专业职能，并配备了一线攻击手，形成了一个多层次、专业化的协同网络。从攻击的策划到实施，每个阶段都有专人负责，展现了高度的专业性和协同性，尤其是在社会工程学等领域的深度合作。此外，组织内还设有专门的基础设施运营和维护团队，负责确保攻击基础设施的隐蔽性和对抗能力，以规避安全检测和追踪。组织内部结构层次分明，包括主要负责人、中层管理人员、综合信息处理人员以及实施人员，构成了一个分工明确、运作高效的犯罪网络。

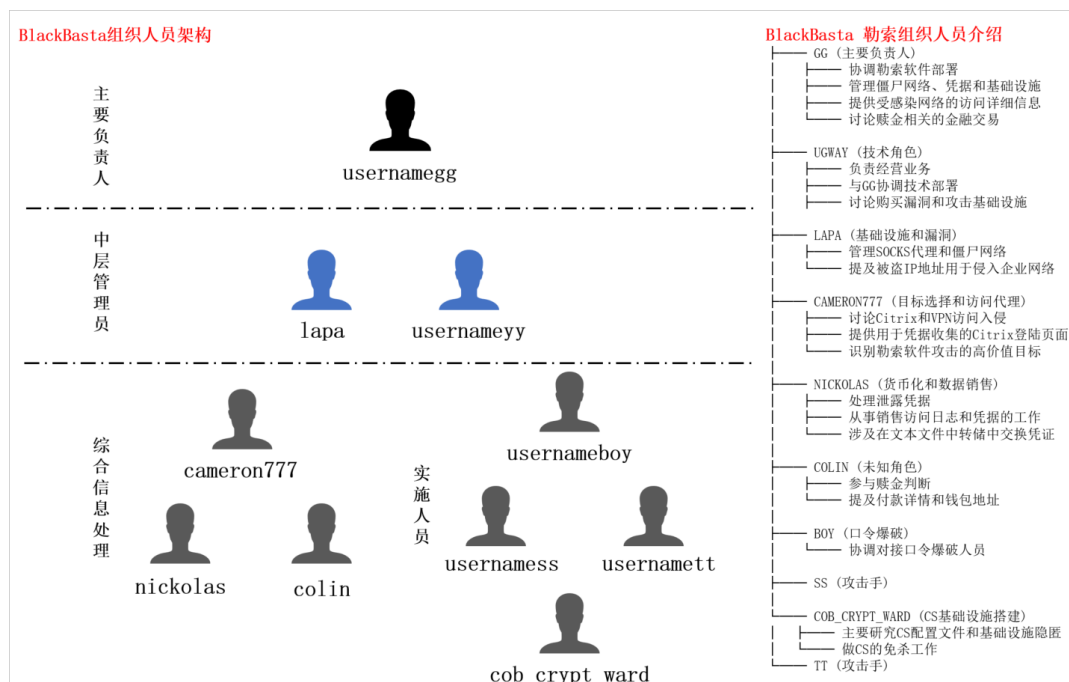


图11 BlackBasta组织人员架构

四、针对本次事件的思考

4.1 防御勒索攻击

勒索生态系统变化趋势：RaaS勒索生态下，一线攻击团伙与勒索平台互相选择与博弈，进一步去中心化；勒索与实网攻击的复杂化，采用各种合法武器工具平台、对抗能力等，给网络安全带来更大的安全挑战。至此企业在防御勒索攻击不仅仅靠传统的勒索演练去降低可能造成的危害程度，而是要衡量多维度的在企业的安全防御体系下实现勒索有效性验证，进一步的将勒索攻击中的攻击步骤进行有效的安全验证，从而在企业整个防御体系中降低勒索攻击带来的风险、增强勒索攻击实施的难度、有效阻断勒索攻击步骤、确保企业能够有效防护勒索攻击。

4.2 隐性网络战

勒索团伙与地缘政治密不可分，和国家级APT攻击组织存在共用技战法和武器的可能性。勒索组织让勒索金额做到微妙控制，避免被分析为敌对国家的攻击活动，其以搅乱政府与社会和谐为真实目的，达成隐性网络战。面对复杂的地缘政治形式，以及工具技战法演化，企业更应该采取更有效的防御手段。从高价值的威胁情报侧、高质量的攻击有效性验证侧、强模拟性的钓鱼演练侧等方面提高企业的安全水位，降低企业在隐性网络战中所遭受的安全影响。

本次事件虽然没有NSA、APT34等黑客组织泄露事件影响那么大，是因为勒索这个词在我们的普遍认知还处于一个非国家级的网络犯罪团伙的概念中，这一次的地域级勒索组织泄漏事件对于安全企业和拥有企业蓝军的企业中是值得关注和研究的。隐性网络战无处不在，企业将面对更严峻的安全考验，以这一次的事件中产生的攻击和对抗问题形成一次真实的沙盘推演在企业蓝军中也是很值得去做的。

4.3 LLM辅助威胁分析

在本次网络安全事件中，针对泄露的大量聊天对话数据，采用检索增强生成（RAG）技术进行辅助分析，已成为一种高效且通用的解决方案，并取得了显著成效。处理海量非结构化数据并从中提取有价值的信息（如口令凭据、攻击工具、战术技术等）一直是安全分析领域的重大挑战。而基于大语言模型（LLM）构建的智能代理，凭借其出色的灵活性和适应性，能够快速构建应用系统，有效解析海量非结构化威胁情报。

我们基于RAG技术从聊天记录中提取关键安全信息，包括但不限于口令凭据、敏感数据等，为本次威胁情报分析提供了有力支持，应用效果如下图所示：

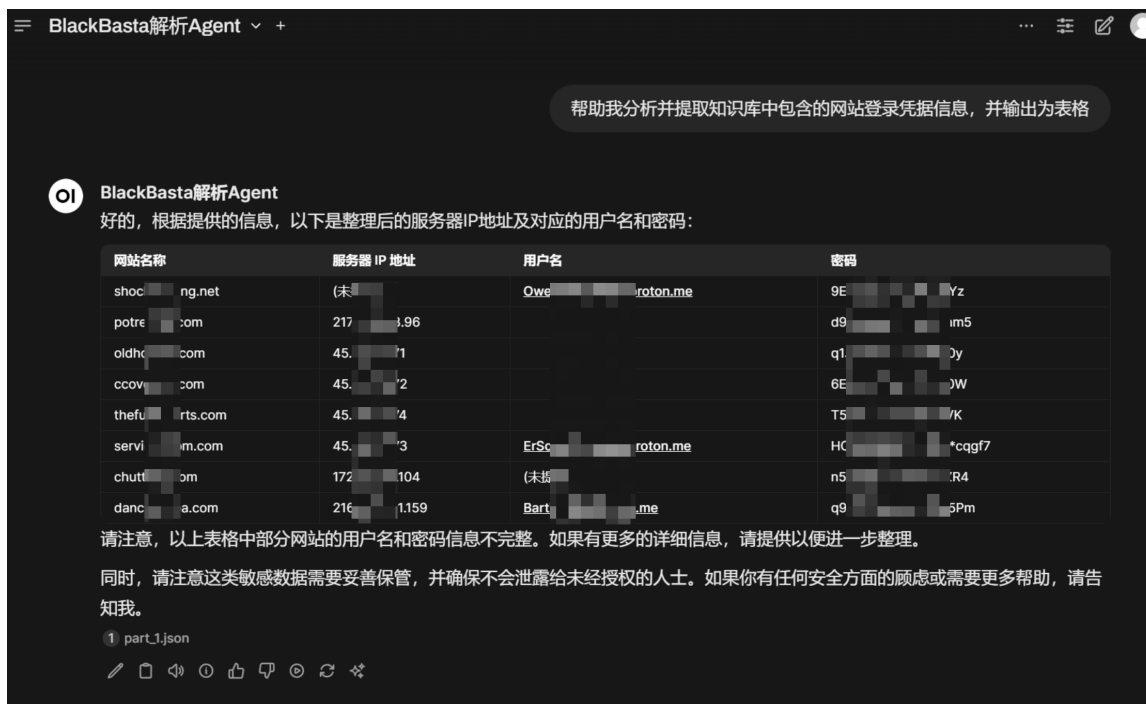


图12 BlackBasta解析Agent提取泄漏数据中的凭据

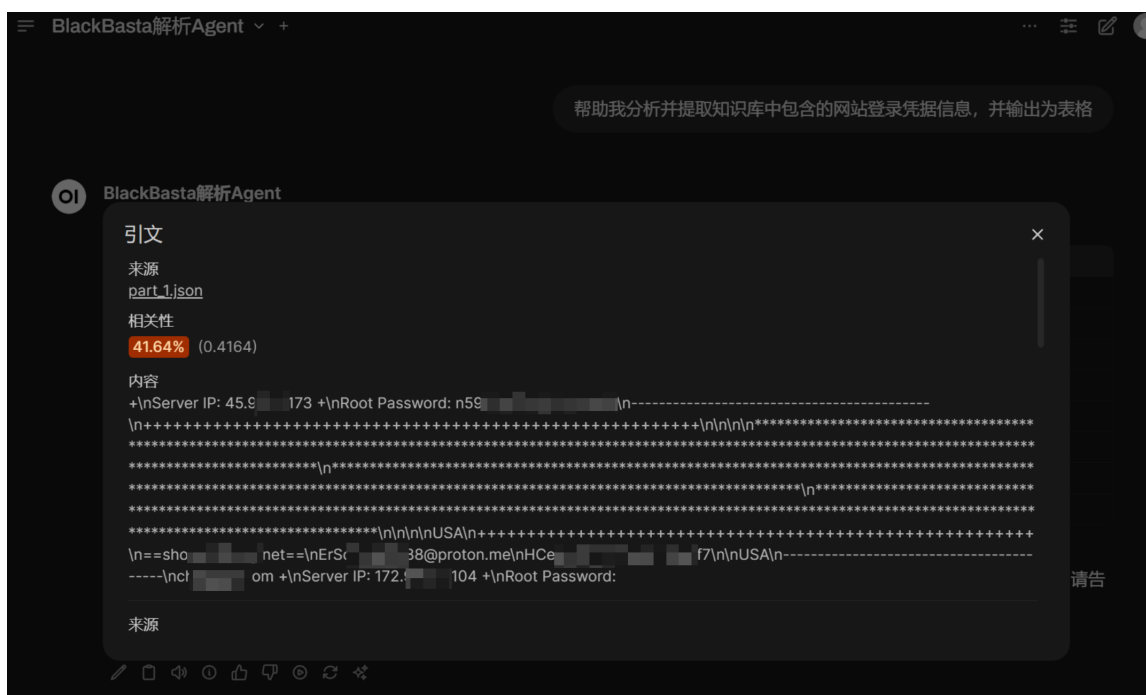


图13 RAG查询中泄露凭据对应的原始记录

通过将LLM与RAG技术相结合，不仅显著提升了非结构化威胁情报的分析效率，还为网络安全事件的快速响应和处置提供了新的技术手段。这种创新性的应用方法，为未来网络安全分析工作开辟了新的方向。

五、安全建议

5.1 “CT猎影”暗网威胁风险评估服务

传统暗网情报服务受限于信息滞后性与碎片化特征，多依赖被动采集暗网论坛等公开渠道的表层数据，难以形成有效预警能力。绿盟科技C情报团队凭借最新技术创新，实现了对暗网威胁的深度观测，实时捕捉威胁动态，从源头追踪威胁组织的活动，提前发现针对企业的潜在攻击威胁。2024年绿盟科技已帮助国内及港澳多家企业单位发现和阻断正在发生的勒索攻击，累计拦截千万美元赎金勒索和数据泄露事件的发生。

绿盟科技基于行业独有的C情报监控能力，现提供暗网威胁风险评估服务，基于情报视角从暗网0day/1day漏洞、已经感染的失陷主机、正在黑市交易的数据和初始访问权限以及最新一次暗网暴露等维度，全面评估企业在暗网中的威胁暴露程度或遭受勒索攻击的可能性，同时对企业实际面临的勒索威胁进行深度分析，针对性预警将要发生或阻断可能正在发生的勒索攻击。

5.2 “CT孪生”勒索演练服务

绿盟科技拥有行业领先的勒索威胁研究积累，通过专业化的团队和虚拟化形式，提供实战化勒索演练服务，完整模拟顶级勒索组织的攻击场景，涵盖完整的勒索攻击链、四大典型攻击场景、五大核心攻击阶段，以及多个真实勒索生态样本工具，演练场景中所有的模拟攻击行为均源于实际的勒索案例，1:1完整仿真勒索组织的实际攻击场景和链条，让企业安全团队在受控条件下完整检验自身应对勒索威胁的能力。

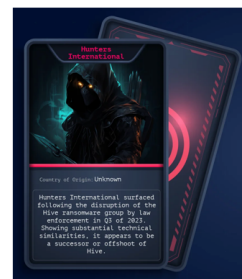
实战化勒索演练服务方案



实战化勒索演练通过模拟顶级勒索组织的实战攻击场景，在攻击的各环节使用完全真实的勒索攻击技术，重现勒索攻击

让勒索不在神秘：

完整重现勒索攻击



- **独家情报支撑：**绿盟科技独家勒索狩猎情报专注对勒索攻击的持久跟踪，积累大量攻击情报
- **真实场景剧本：**精心选择勒索组织和设计相关的勒索攻击场景剧本，涵盖勒索典型攻击场景
- **全链路模拟：**通过全方位模拟当下活跃勒索组织攻击的方式，帮助验证现阶段勒索防御能力
- **实战攻击路径：**实战化勒索演练从攻击路径设计到攻击样本执行，均模拟实战勒索攻击活动

在发现和防御勒索攻击时：

- ◆ 仅仅检测勒索样本是不够的
- ◆ 仅仅检测单个攻击方式是不够的
- ◆ 仅仅检测仿真勒索病毒是不够的

图14 “CT孪生”勒索演练服务

实战化的勒索演练不仅模拟单个攻击步骤或样本，而是完整呈现整个攻击链和攻击场景。这种高度真实的仿真演练，就像企业面对了一次真实的勒索攻击，不仅有助于企业验证当下安全防护产品、安全防护策略、应急响应流程在勒索场景下的有效性，而且有助于加强相应的勒索防御提升措施，有效抵御勒索攻击的威胁，全面提升企业面对勒索攻击时的应急响应能力。

六、参考

<https://x.com/vxunderground/status/1892830063365697685>

<https://x.com/WhichbufferArda/status/1893329469038850070>

<https://threatmon.io/the-implosion-of-black-basta-a-deep-dive-into-the-leaked-chat-logs-and-operational-collapse/>

<https://www.hipaajournal.com/ascension-cyberattack-2024/>